

Information Security Policy

DRAFT template - finalize with counsel / security lead. Summarises Vertofi's security posture for customers and partners.

VERTOFI PRIVATE LIMITED (CIN U62099TS2026PTC211039) is committed to protecting the confidentiality, integrity and availability of customer information.

1. Governance

Security is owned at the leadership level. Policies are reviewed at least annually and after significant changes. The company works toward SOC 2 and ISO 27001 alignment.

2. Access control

- Role-based and attribute-based access control with least privilege.
- Multi-factor authentication; step-up verification for sensitive financial actions.
- Strict tenant isolation enforced at the database layer (row-level security); financial data additionally has column-level security.
- Internal administration tooling is restricted to authorised staff on the internal network only.

3. Encryption

- In transit: TLS 1.2+ (mutual TLS internally).
- At rest: managed-key encryption for databases, object storage and volumes; field-level encryption for the most sensitive identifiers, with keys held in a secrets vault.

4. Secrets management

Credentials and keys are stored in a managed secrets vault, rotated, and never committed to source control, environment files in version control, or logs.

5. Network & application security

Web application firewall, DDoS protection, rate-limiting, default-deny network policies, parameterized queries, input validation, secure headers, and signature-verified webhooks.

6. Logging & monitoring

Centralised metrics, traces and logs; an immutable, hash-chained audit log of financial actions and administrative access; alerting on security and availability events.

7. Vulnerability & change management

Automated dependency, code (SAST) and container scanning in CI; reviewed, gated releases with the ability to roll back; periodic penetration testing (planned).

8. Data handling & retention

Data minimisation; defined retention aligned to legal and tax requirements; secure deletion or anonymisation thereafter.

9. Business continuity & DR

Multi-AZ resilience, backups with point-in-time recovery, cross-region replication for critical assets, and tested recovery procedures.

10. Incident response

Documented incident-response process with defined roles, customer notification for breaches affecting their data, and post-incident review.

11. Personnel & sub-processors

Confidentiality obligations for personnel; due diligence and contractual security obligations for sub-processors.

12. Reporting

Report security concerns to [security@vertofi.com].

This is a template and does not constitute legal advice.